Assignment Week 3

1. OSINT & Recon Lab
Subdomain Enumeration (Recon-ng)
Module used: bing_domain_web (conceptual, since API needed)

Output Log

Subdomain	IP Address	Notes
www.example.com	93.184.216.34	Hosts web server
mail.example.com	93.184.216.34	Mail service
dev.example.com	93.184.216.34	Development server

Shodan Query
Query Used:
apache country:US
Summary (50 words)
Shodan search results reveal multiple Apache servers exposed in the US with open ports such as 80 and 443. Some hosts show outdated Apache versions, increasing vulnerability risk. Misconfigured servers expose directories and sensitive headers, indicating poor security practices and potential entry points for attackers.

---

2. Phishing Simulation
Credential Harvest Log

Timestamp	IP Address	Username/Password	Risk	Notes
2025-08-29 12:00:00	192.168.1.50	testuser/pass123	High	Successful capture
2025-08-29 12:05:00	192.168.1.51	admin/admin123	High	Weak credentials

---

Explanation

- **Gophish** → used to send phishing emails
- **Evilginx2** → clones login pages

---

3. Vulnerability Exploitation
Scan & Exploit Log

Vulnerability	CVSS Score	Description
Struts RCE	9.8	Remote code execution
Open SSH Port	7.5	Brute-force possible

Tools Used

- **Nmap**
- **Metasploit**

- **OWASP ZAP**

Remediation

- Update Apache Struts library
- Disable unused ports
- Apply firewall rules

4. Lateral Movement Exercise

Summary (50 words)

After initial compromise, lateral movement was achieved using credential reuse and SMB exploitation. Impacket's psexec.py enabled remote command execution across systems. The attacker pivoted between hosts within the network, escalating privileges and maintaining persistence, demonstrating how weak internal segmentation allows attackers to spread rapidly across enterprise environments.

Persistence Log

Technique	Tactic	Description	Notes
Scheduled Task	Persistence	T1053	Runs payload daily

5. Social Engineering Lab

Intel Gathering Log

Target ID	Data Source	Information	Notes
TID001	PhoneInfoga	Phone: 555-1234	Linked to target

Vishing Summary (50 words)

A pretexting scenario was created where the attacker impersonated an IT support executive requesting login verification. Using gathered phone data, the attacker gained trust and extracted credentials. The simulation highlights how human manipulation remains one of the weakest security points despite strong technical defenses.

6. Exploit Development Basics

Findings (50 words)

Binary analysis revealed hardcoded strings, unsafe buffer handling, and lack of input validation. Using GDB, memory overflow points were identified. The program lacked stack protection mechanisms, making it vulnerable to buffer overflow attacks. These weaknesses allowed controlled execution flow manipulation and potential arbitrary code execution.

7. Post-Exploitation & Exfiltration

Credential Dump Log

Hash Type	Username	Hash Value
NTLM	Administrator	aad3b435b514...

Exfiltration

- Data exfiltrated using DNS tunneling

- Avoided firewall detection
- Demonstrated stealth techniques

---

8. Red Team Report

Executive Summary

The engagement simulated a real-world cyberattack, identifying vulnerabilities across reconnaissance, phishing, exploitation, and post-exploitation stages. Weak configurations and human factors enabled compromise, demonstrating the importance of layered security defenses.

Findings

- Subdomain exposure
- Weak credentials
- Unpatched vulnerabilities
- Poor network segmentation

Recommendations

- Patch management
- Security awareness training
- Network segmentation
- Strong authentication

Attack Flow

Recon → Phishing → Exploitation → Lateral Movement → Exfiltration

---

9. Capstone Project

Attack Log

Phase	Tool Used	Action Description	MITRE Technique
Recon	Recon-ng	Subdomain enum	T1595
Access	Gophish	Phishing attack	T1566
Exploit	Metasploit	RCE exploit	T1203

Blue Team Log

Timestamp	Alert Description	Source IP	Notes
2025-08-29 13:00:00	Suspicious Login	192.168.1.50	Phishing attempt

---

Final Report (200 words)

The simulated red team engagement demonstrated a full attack lifecycle beginning with reconnaissance and ending in data exfiltration. During reconnaissance, exposed subdomains and services were identified, increasing the attack surface. A phishing campaign successfully captured user credentials, enabling initial access. Exploitation of unpatched vulnerabilities allowed remote code execution on target systems.
Following access, lateral movement was achieved using credential reuse and SMB exploitation, highlighting poor internal segmentation. Sensitive credentials were extracted

using post-exploitation tools, and data exfiltration was conducted via DNS tunneling to avoid detection.
Blue team analysis revealed detection opportunities during login anomalies and unusual network traffic. However, delayed response allowed attackers to maintain persistence.
The engagement emphasizes the need for timely patching, strong authentication mechanisms, user awareness training, and continuous monitoring. Implementing zero-trust architecture and network segmentation can significantly reduce attack impact.

🗣 Non-Technical Summary (100 words)

This simulation showed how attackers can break into systems using a combination of technical vulnerabilities and human mistakes. By collecting public information, tricking users into sharing credentials, and exploiting outdated software, attackers gained control of systems and accessed sensitive data. The exercise highlights the importance of keeping systems updated, training employees to recognize phishing attempts, and monitoring suspicious activity. Strengthening internal security controls and using modern protection strategies can greatly reduce the risk of such attacks and protect organizational data from breaches.